

Access Control

Models and Principles

Course: BSCS 3110 — Information Assurance and Security

Week 5 · 3 hours · Lecture

What you should be able to do after this material

- **Knowledge:** Define access control and explain identification, authentication, and authorization.
- **Skills:** Compare and contrast the main access control models — DAC, MAC, RBAC, and ABAC.
- **Attitude:** Appreciate the Principle of Least Privilege as a cornerstone of robust security.

1. Why access control matters

In the first weeks of this course you learned that information security protects the confidentiality, integrity, and availability of data. Access control is the mechanism that actually enforces those goals in day-to-day operation. It is the set of rules and technologies that decide **who** is allowed to do **what** to **which** resource. Without it, a policy that says “only the registrar may change grades” is just a sentence on paper.

Think of a university. A student should see their own grades but not change them. A professor should change grades for their own classes but not for another department. The registrar can correct records across the whole institution. Access control is what turns those intentions into enforced, checkable rules. When it is done well, it is invisible. When it is done badly, it is how a curious clerk reads records they should never see, or how a single stolen password exposes an entire database.

2. The three steps: identification, authentication, authorization

Every access decision moves through three steps, in order. Students often blur them together, but they answer three different questions and use different mechanisms.

Step	The question it answers	Everyday example
Identification	Who do you claim to be?	Typing your username or student number.
Authentication	Can you prove it?	Entering your password, a one-time code, or scanning a fingerprint.
Authorization	What are you allowed to do?	The system checks that this account may open the grades file.

Key distinction to remember

Authentication proves **who you are**. Authorization decides **what you may do**. A valid login does not automatically grant access to everything — you can be correctly authenticated and still be denied, because authorization is a separate check.

2.1 Factors of authentication

Authentication relies on one or more **factors**. Combining factors from different categories — called multi-factor authentication (MFA) — is far stronger than any single one, because an attacker must defeat two unrelated things at once.

- **Something you know** — a password, a PIN, an answer to a security question.
- **Something you have** — a phone that receives a code, a hardware token, an ID card.
- **Something you are** — a fingerprint, a face scan, or another biometric trait.

3. The Principle of Least Privilege

The Principle of Least Privilege (PoLP) states that every user, program, or process should be given **only the access it needs to do its job, and no more**. A teaching assistant who only records attendance does not need permission to edit final grades. A backup script that only reads files does not need permission to delete them.

Least privilege matters because it limits the **blast radius** when something goes wrong. If an account is compromised, or a user makes a mistake, the damage is capped at whatever that account was allowed to touch. An over-privileged account is a single point of catastrophic failure; a least-privileged one is a contained incident.

Least privilege in one sentence

Give each account the smallest set of permissions that still lets it do its legitimate work — then a stolen password or a careless click can only reach that small set, not everything.

A closely related idea is **separation of duties**: no single person should control an entire sensitive process from start to finish. The person who requests a payment should not also be the one who approves it. Together, least privilege and separation of duties make both mistakes and insider abuse much harder.

4. Access control models

An access control **model** is the overall strategy an organization uses to decide who gets access to what. The core three you must be able to compare are DAC, MAC, and RBAC; a fourth, ABAC, extends the idea and is increasingly common. They differ in one key question: **who or what has the authority to grant access?**

4.1 Discretionary Access Control (DAC)

In DAC, the **owner** of a resource decides who may access it. If you create a file, you can choose to share it, and with whom. This is the model behind file sharing on Windows, macOS, and Google Drive — the person who owns the document sets the permissions.

- **Strength:** Flexible and easy for users; access can be granted quickly by whoever owns the resource.
- **Weakness:** Inconsistent and hard to govern at scale. Owners can grant access carelessly, and permissions sprawl over time.
- **Best fit:** Small teams and personal or collaborative file sharing where flexibility matters more than strict control.

4.2 Mandatory Access Control (MAC)

In MAC, a **central authority** sets access rules based on classification **labels**, and individual users cannot change them. Data is labelled (for example, Confidential, Secret, Top Secret) and users are

given a clearance level. Access is granted only when a user's clearance meets the data's label. This is the model used by militaries and intelligence agencies.

- **Strength:** Extremely strong and consistent; users cannot override the rules, so accidental oversharing is impossible.
- **Weakness:** Rigid and administratively heavy; every user and resource must be labelled and maintained centrally.
- **Best fit:** High-security environments — military, government, and anywhere data classification is legally required.

4.3 Role-Based Access Control (RBAC)

In RBAC, access is granted to **roles** rather than to individuals, and users are assigned to roles based on their job. A “Registrar” role can edit grades; anyone placed in that role inherits that permission. When a person changes jobs, you simply change their role rather than re-editing dozens of individual permissions. This is the model used by most companies, universities, and cloud platforms today.

- **Strength:** Scales well and maps cleanly to how organizations actually work; onboarding and role changes are simple.
- **Weakness:** Requires careful upfront design of roles; poorly designed roles lead to “role explosion” or over-broad access.
- **Best fit:** Most medium-to-large organizations — the practical default for businesses and schools.

4.4 Attribute-Based Access Control (ABAC)

In ABAC, access is decided by **attributes** and **rules** rather than by ownership, labels, or a fixed role. An attribute is any fact about the **user** (department, clearance, job title), the **resource** (its classification, owner, type), or the **context** (time of day, location, device). Rules combine these into policies such as: “allow access if the user is in the Finance department AND the request is during office hours AND the device is company-managed.” This is the model behind modern cloud platforms and zero-trust systems.

- **Strength:** Extremely fine-grained and flexible; a single policy can express conditions that would need many separate roles in RBAC.
- **Weakness:** Complex to design and to audit; with many attributes it can be hard to predict exactly who gets access, and mistakes are easy to hide.
- **Best fit:** Large, dynamic environments — cloud services, zero-trust networks, and systems where access must depend on context, not just identity.

RBAC vs. ABAC in one line

RBAC asks “**what is your role?**” and grants access to that role. ABAC asks “**what are the facts about you, the resource, and right now?**” and evaluates a rule. ABAC can do everything RBAC does and more, at the cost of greater complexity — which is why many organizations start with RBAC and add ABAC rules only where they need context.

5. The four models side by side

This is the comparison you should be able to reproduce and reason about. The deciding row is “Who or what grants access?” — everything else follows from it.

	DAC	MAC	RBAC	ABAC
Grants access by	Owner’s choice	Classification label	Assigned job role	Attributes + rules
Basis of decision	Owner discretion	Clearance vs. label	The user’s role	User, resource, context
Flexibility	High	Low	Medium	Very high
Consistency / control	Low	Very high	High	High (if well designed)
Scales to large orgs?	Poorly	Heavy admin	Well	Well, but complex
Typical use	File sharing	Military, gov’t	Companies, schools	Cloud, zero-trust

How to choose — the reasoning your case study will need

There is no single “best” model; the right choice depends on the organization’s need for **flexibility** versus **control**. A start-up sharing design files values flexibility, so DAC or RBAC fits. A military base handling classified data values control above all, so MAC fits. A university needs consistency across thousands of users with clear job roles, so RBAC fits best. A cloud platform that must also weigh time, device, and location leans on ABAC. When you justify a choice, name the organization’s priorities first, then match the model to them.

6. Worked example: two organizations, two choices

The graded case study for this week asks you to choose and justify a model for different organizations. Here is the kind of reasoning that earns full marks — notice that it starts from the organization’s priorities, not from the model.

A university registrar system

Thousands of users fall into a handful of clear job types: students, professors, department heads, and registrar staff. Permissions should follow the job, not the person, and must stay consistent as people enrol, graduate, and change departments. **RBAC** fits: define roles once, assign people to them, and access stays correct as individuals come and go. DAC would be chaos at that scale; MAC's classification labels are more rigidity than a university needs.

A military intelligence unit

Data is classified by sensitivity, disclosure can be catastrophic, and no individual may be allowed to widen access on their own. Control matters far more than convenience. **MAC** fits: a central authority sets clearances and labels, and the system enforces them regardless of what any user wants. RBAC alone would not capture the strict clearance-versus-classification rule that this environment legally requires.

7. Key terms to review

Term	Meaning
Access control	The rules and technologies that decide who may do what to which resource.
Identification	Claiming an identity (e.g., a username).
Authentication	Proving that claimed identity (e.g., a password or biometric).
Authorization	Deciding what an authenticated user is permitted to do.
Least Privilege	Granting only the minimum access needed to do a job.
Separation of duties	Splitting a sensitive task so no one person controls it all.
DAC	Owner decides access. Flexible, hard to govern at scale.
MAC	Central authority decides by classification labels. Strict, rigid.
RBAC	Access follows job roles. Scalable, the common default.
ABAC	Access follows attributes and rules about the user, resource, and context. Very flexible, more complex.

8. Check your understanding

Answer these before the graded case study. Answers are on the last page.

- 1 You type your student number, then your password, then the system lets you view (but not edit) your grades. Name the three access-control steps happening, in order.
- 2 A backup script only needs to read files, but it was given permission to delete them too. Which principle is being violated, and why is that dangerous?

- 3 In which model does the *owner* of a file decide who can open it?
- 4 A hospital must enforce data classifications that no staff member can override on their own. Which model fits best, and why?
- 5 Your friend says “I logged in successfully, so I should be able to open any file.” Explain why that reasoning is wrong, using the words authentication and authorization.
- 6 A company wants a rule like “allow access only from a company laptop, during office hours, for staff in the Finance team.” Which model is designed to express conditions like this, and why can RBAC alone not do it cleanly?

Answer key — Check your understanding

- 1 Identification (student number), authentication (password), authorization (allowed to view but not edit).
- 2 The Principle of Least Privilege. Giving delete rights the script does not need means that if the script is compromised or buggy, it can destroy data — the extra permission widens the blast radius for no benefit.
- 3 Discretionary Access Control (DAC).
- 4 Mandatory Access Control (MAC), because a central authority sets classification labels and clearances that individual users cannot override — exactly what strict data classification requires.
- 5 A successful login is only authentication — it proves who you are. What you may open is decided separately by authorization. You can be correctly authenticated and still be denied access to files your account is not permitted to use.
- 6 Attribute-Based Access Control (ABAC). The rule depends on several attributes at once — device, time, and team — including live context like the time of day. RBAC grants access by a fixed role and cannot easily factor in conditions such as “only during office hours” or “only from a company laptop” without creating an unmanageable number of special roles.

Looking ahead

Access control decides *who* may reach data. Cryptography, which you will meet in a later week, protects the data itself even from those who reach it. The two work together: access control keeps most people out, and encryption protects what remains if they get in.